

Audit technique complet

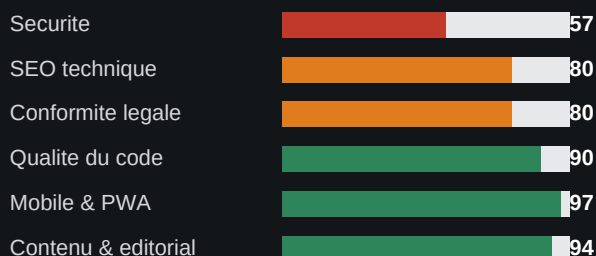
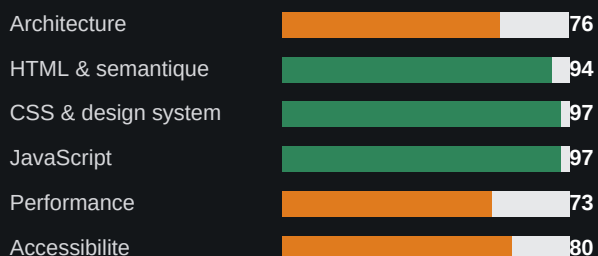
The Hub — the-hub-vrc.fr

Next.js 16.2.11 (App Router) / React 19.2.4 / TypeScript 5.9.3 / Prisma 6.19.3 + PostgreSQL / Tailwind CSS 4 / Auth.js 5 beta 32 / sharp 0.35 - deploiement standalone + PM2 derriere Apache (OVH Kimsufi)



Findings par severite

Critique	0
Majeur	17
Mineur	22
Info	1
Total	40



1. Synthese executive

Le projet est un site Next.js 16 (App Router) consacre au Tier 3 Valorant francophone, developpe par une seule personne et deja en production sur un serveur OVH Kimsufi. L'audit a porte sur 151 fichiers source (~15 000 lignes), les configurations de build, de deployment et de CI, ainsi que les dependances.

Verdict : base technique saine, exposition operationnelle a corriger. Le code lui-meme est d'une qualite nettement au-dessus de la moyenne pour un projet de cette taille : aucun secret en dur, autorisation verifiee a la fois au niveau des pages et des server actions, validation Zod systematique, aucun motif XSS, protection correcte contre la traversée de repertoire, 169 tests unitaires verts et compilation TypeScript sans erreur. Aucun finding de severite critique n'a ete identifie. Les faiblesses se concentrent sur ce qui entoure le code : en-tetes de securite incomplets, outillage qualite absent, contenus legaux inaccessibles sur mobile et references SEO manquantes.

Les cinq points a traiter en premier

#	ID	Constat	Sev.	Eff
1	LEG-01	Liens vers les mentions legales, la confidentialite et les CGU masques sous 640 px	Majeur	S
2	LEG-02	Images tierces (flagcdn.com, media.valorant-api.com) non declarees dans la politique de confidentialite	Majeur	M
3	A11Y-01	Aucun lien d'evitement vers le contenu principal	Majeur	S
4	A11Y-02	Contraste insuffisant du token --text-subtle (3,5:1)	Majeur	S
5	PERF-03	Logo de navigation de 98 Ko pour un rendu de 32 px de haut	Majeur	S

Ces cinq points partagent une caracteristique : ils ont un effort de correction faible (S ou M) et un impact direct sur la conformite ou l'experience reelle des visiteurs. Les trois premiers se corrigent en modifiant moins de dix lignes chacun.

Ce qui est deja solide

- ✓ Aucun secret en dur : les 6 variables sensibles passent toutes par process.env, .env* ignore par git (seul .env.example est versionne).
- ✓ Autorisation systematique et centralisee : requireAdmin / assertCanManageTeam / assertCanManageTournament appliques a la fois au niveau page (7 pages admin, layouts de gestion) ET au niveau server action (matches.ts, teams.ts, tournaments.ts, equipes/actions.ts, tournois/actions.ts).
- ✓ Aucun pattern XSS : 0 dangerouslySetInnerHTML, 0 innerHTML, 0 eval, 0 document.write, 0 `any` dans tout src/.
- ✓ Traversée de repertoire correctement bloquee sur /api/images (allowlist de categories + rejet de .., / et \ + verification du prefixe resolu) - src/lib/images.ts:30-42.
- ✓ Validation d'entree par schemas Zod dans src/lib/validation/ (6 modules), utilisee par les server actions.
- ✓ 169 tests unitaires verts (18 fichiers), `tsc --noEmit` sans erreur, CI GitHub Actions qui bloque sur types + tests + build.
- ✓ Pages legales completes et redigees (mentions legales LCEN, politique de confidentialite RGPD detaillee avec sous-traitants et durees de conservation, CGU) - aucun marqueur [A COMPLETER] restant.
- ✓ Aucun traceur tiers (0 occurrence de GA / GTM / Meta Pixel / Hotjar / Matomo / Plausible) : l'absence de bandeau cookies est donc juridiquement coherente.
- ✓ Deployment soigne : releases horodatees, symlinks pour uploads/.env, empreinte SSH epinglee (SSH_KNOWN_HOSTS), garde-fou sur APP_DIR, migrations avant bascule.
- ✓ Aucun TODO / FIXME / HACK dans le code source.
- ✓ 17 blocs @media (prefers-reduced-motion: reduce) : les animations respectent la preference systeme.

2. Sommaire

1.	Synthese executive
2.	Sommaire
3.	Methodologie et perimetre
4.	Tableau de bord par domaine
5.	Architecture (5 findings)
6.	HTML & semantique (2 findings)
7.	CSS & design system (1 finding)
8.	JavaScript (1 finding)
9.	Performance (5 findings)
10.	Accessibilite (4 findings)
11.	Securite (9 findings)
12.	SEO technique (4 findings)
13.	Conformite legale (4 findings)
14.	Qualite du code (2 findings)
15.	Mobile & PWA (1 finding)
16.	Contenu & editorial (2 findings)
17.	Plan d'action priorise
18.	Annexes : commandes, outils, ce qui n'a pas ete teste

3. Methodologie et perimetre

L'audit est **statique** : il porte sur le code source, les configurations et les dependances du depot, sans instance du site en fonctionnement. Cette limite est assumee et explicitee : la base PostgreSQL de production n'etait pas accessible depuis le poste d'audit, ce qui exclut Lighthouse, pa11y, axe-core et la validation W3C, tous dependants d'URLs reellement serves. La section 17 detaille point par point ce qui n'a pas pu etre teste.

Chaque finding cite le fichier et la ligne qui l'etablissent. Aucune mesure n'est extrapolee : les tailles proviennent du systeme de fichiers, les vulnerabilites de npm audit, les ratios de contraste d'un calcul WCAG applique aux valeurs de `globals.css`, et les comptages de recherches exhaustives sur l'arborescence `src/`.

Bareme de notation

Chaque domaine part de 100 points, dont on retrace 15 points par finding critique, 7 par majeur, 3 par mineur et 0 pour les informations. Le score global est la moyenne de ces douze notes, ponderee selon l'exposition au risque : Securite 15 %, Accessibilite, Performance et Conformite legale 12 % chacune, Qualite du code, Architecture et SEO 10 % chacune, JavaScript 5 %, CSS et HTML 4 % chacun, Mobile et Contenu 3 % chacun. Le bareme est arbitraire mais explicite : il sert a hierarchiser, pas a certifier.

Severite	Definition	Nb
Critique	Vulnerabilite exploitable ou perte de donnees. Bloque la mise en production.	0
Majeur	Defaut fonctionnel, de conformite ou de qualite avec impact reel sur les visiteurs.	17
Mineur	Point de maintenabilite ou d'optimisation, sans consequence immediate.	22
Info	Observation ou controle non realise, communique pour information.	1

L'effort est estime en S (moins d'une heure), M (une demi-journee a deux jours) et L (au-dela).

4. Tableau de bord par domaine

Domaine	Score		Maj.	Min.	Info	Poids
Architecture	76		3	1	1	10 %
HTML & semantique	94		0	2	0	4 %
CSS & design system	97		0	1	0	4 %
JavaScript	97		0	1	0	5 %
Performance	73		3	2	0	12 %
Accessibilite	80		2	2	0	12 %
Securite	57		4	5	0	15 %
SEO technique	80		2	2	0	10 %
Conformite legale	80		2	2	0	12 %
Qualite du code	90		1	1	0	10 %
Mobile & PWA	97		0	1	0	3 %
Contenu & editorial	94		0	2	0	3 %
Score global pondere	79		17	22	1	100 %

Lecture : la Securite est le domaine le plus penalise (57/100), non pas a cause d'une faille dans le code applicatif - il n'y en a pas - mais parce que quatre protections d'infrastructure attendues sont absentes (CSP, HSTS, limitation de debit, correctif postcss). La Performance (73) et l'Architecture (76) suivent, sur des points d'outillage et d'optimisation. Les domaines lies a la redaction du code lui-meme - CSS, HTML, JavaScript, Qualite - sont tous au-dessus de 90.

5. Architecture

Score **76/100**

Poids 10 %

Organisation du depot, outillage qualite, tests et integration continue.

ARC-01	Aucun linter configure, avec 38 directives eslint-disable orphelines	Majeur · M
Emplacement	package.json:33-43 (devDependencies), racine du projet : 33-43	
Constat	Ni ESLint, ni Prettier, ni Stylelint, ni Biome en dependance ; aucun fichier eslint.config.*, .prettierrc ou .stylelintrc a la racine. Le code contient pourtant 38 commentaires `// eslint-disable-next-line @next/next/no-img-element` (nav-bar.tsx:27, flag.tsx:20, agent-icon.tsx:23, lft-card.tsx:39, etc.) : des directives qui ne desactivent plus rien puisqu'aucun linter ne tourne. C'est la trace d'un outillage supprime ou jamais installe.	
Impact	Aucun garde-fou automatique sur les regles React/Next (hooks, exhaustive-deps, no-img-element), aucune uniformite de formatage. Les 38 directives donnent la fausse impression que le point a ete arbitre.	
Correction	Installer eslint + eslint-config-next + @typescript-eslint et ajouter un script `lint` appele par la CI. Traiter ensuite les 38 exceptions : soit passer a next/image, soit conserver et desactiver la regle une fois pour toutes dans la configuration.	

ARC-02	Tests end-to-end absents de la CI et du deploiement	Majeur · M
Emplacement	.github/workflows/ci.yml, .github/workflows/deploy.yml : 20-42 / 26-42	
Constat	7 suites Playwright existent (tests/e2e/auth, enrichments, matches, players, search, teams, tournaments). Aucun des deux workflows ne mentionne playwright ni `npm run test:e2e` : ils s'arretent aux tests unitaires et au build. playwright.config.ts:6-11 demarre par ailleurs `npm run dev`, pas le serveur de production.	
Impact	Les parcours critiques (connexion Discord, inscription d'equipe a un tournoi, recherche) ne sont verifies que manuellement. deploy.yml pousse en production des qu'un push sur main passe types + tests unitaires + build.	
Correction	Ajouter un job E2E a la CI avec un service PostgreSQL, `npx playwright install --with-deps` et une base amorcee par prisma/seed-dev.ts. Basculer le webServer de playwright.config.ts sur `npm run build && npm start` pour tester ce qui est reellement deploye.	

ARC-03	Couverture de tests non mesuree	Majeur · S
Emplacement	vitest.config.ts : 5	
Constat	La configuration se limite a `test: { environment: 'node', include: ['tests/unit/**/*.test.ts'] }` : aucun bloc coverage, aucun paquet @vitest/coverage-*, aucun script `test:coverage`, aucun seuil. Les 169 tests portent sur les modules purs (validation, bracket, standings, crop, match-stats, henrikdev, permissions, images, invite, dates, agents, lft) ; la couche donnees (src/lib/data/, 9 modules) et les server actions n'ont aucun test unitaire.	
Impact	Impossible de savoir ce qui est reellement couvert, ni de detecter une regression de couverture. L'objectif de 80 % fixe par les regles du projet n'est ni mesure ni atteignable a l'aveugle.	
Correction	Installer @vitest/coverage-v8, activer coverage avec des seuils (lines/functions 80 %) et publier le rapport en artefact de CI. Commencer par mesurer avant de fixer le seuil bloquant.	

ARC-04	README reste le gabarit create-next-app	Mineur · S
Emplacement	README.md : 1-36	
Constat	Les 36 lignes sont le texte genere par create-next-app : « bootstrapped with create-next-app », port 3000 (le projet tourne sur 3200, package.json:7), mention de la police Geist (le projet utilise Plus Jakarta Sans / Bricolage Grotesque), et une section « Deploy on Vercel » alors que le deploiement se fait sur un serveur OVH via PM2. La vraie documentation existe mais est ailleurs (docs/DEPLOIEMENT.md, AGENTS.md, 10 documents dans docs/superpowers/).	
Impact	Premier fichier lu par tout nouvel arrivant, et il est trompeur sur trois points verifiables. Aucune procedure d'installation locale reelle (base PostgreSQL, prisma migrate, variables .env).	
Correction	Reecrire le README : pile technique, prerequis, mise en route (.env.example, npm run db:migrate, db:seed:dev), scripts disponibles, et liens vers docs/DEPLOIEMENT.md.	

ARC-05	Pas de .editorconfig	Info · S
Emplacement	racine du projet	
Constat	Aucun .editorconfig. Le style reel du code est pourtant tres homogene (2 espaces, guillemets doubles, point-virgules).	
Impact	Rien aujourd'hui - projet a un seul contributeur. Deviendra une source de bruit dans les diffs des qu'un second editeur interviendra.	
Correction	Ajouter un .editorconfig minimal en meme temps que Prettier (voir ARC-01).	

6. HTML & sémantique

Score 94/100

Poids 4 %

Structure du document, métadonnées et données de partage. Le HTML étant généré par React Server Components, l'analyse porte sur le JSX et l'API Metadata de Next.

HTM-01	openGraph.url figée sur l'accueil pour toutes les pages	Mineur · S
Emplacement	src/app/layout.tsx : 48	
Constat	`openGraph: { ..., url: SITE_URL }` est déclarée dans le layout racine et n'est surchargée par aucune page. Les 14 pages qui définissent des métadonnées dynamiques via generateMetadata (equipes/[id], joueurs/[id], matches/[id], tournois/[id]...) ajustent bien leur titre mais héritent de cette URL.	
Impact	Toute carte de partage - Discord au premier chef, canal principal de ce public - annonce l'URL de l'accueil, quelle que soit la page réellement partagée. Le titre reste correct, mais l'URL affichée est fautive.	
Correction	Retirer `url` du layout et la définir dans chaque generateMetadata, ou passer par `alternates.canonical` que Next reporte automatiquement sur og:url.	

HTM-02	Aucune URL canonique déclarée	Mineur · S
Emplacement	src/app/layout.tsx : 31-56	
Constat	Aucune occurrence de `alternates` ou `canonical` dans src/. Or plusieurs pages acceptent des paramètres d'URL : /recherche?q=..., /tournois avec ses filtres (tournament-filters.tsx), /lft avec les siens (lft-filters.tsx), et les redirections d'erreur ajoutent ?error=... (une quinzaine de variantes dans les server actions).	
Impact	Chaque combinaison de filtres devient une URL indexable distincte pour un contenu quasi identique : dilution du signal et budget d'exploration gaspillé.	
Correction	Déclarer `alternates: { canonical: ... }` dans le layout et dans les generateMetadata des pages dynamiques, en pointant vers l'URL sans paramètre.	

7. CSS & design system

Score 97/100



Poids 4 %

Architecture des feuilles de style, jetons de charte, responsive et volume produit.

CSS-01	globals.css monolithique de 1 392 lignes	Mineur · M
Emplacement	src/app/globals.css : 1-1392	
Constat	Fichier CSS unique de 1 392 lignes, tres au-dela du plafond de 800 lignes fixe par les regles du projet. Il melange les tokens de la charte (lignes 3-50), les tokens du kit d'animation transitions-dev (lignes 59+) et 17 blocs @media, tous consacres a prefers-reduced-motion (le responsive passe entierement par les classes utilitaires Tailwind), chacun rattache a un composant d'animation different.	
Impact	Purement structurel : le CSS produit ne fait que 68 Ko et la qualite est bonne (tokens nommes, commentaires explicatifs, prise en charge systematique de prefers-reduced-motion). Le cout se paie a la maintenance, ou il faut parcourir tout le fichier pour situer une regle.	
Correction	Scinder en plusieurs feuilles importees depuis globals.css : tokens.css (charte), base.css (elements), animations.css (snippets transitions-dev et leurs media queries). Le decoupage est mecanique, Tailwind 4 gere les @import.	

8. JavaScript

Score **97/100**

Poids 5 %

Etat des dependances, motifs dangereux, typage. Les controles d'anti-motifs de performance (document.write, XHR synchrone, eval) sont tous negatifs.

JS-01	Neuf dependances en retard, dont next et react	Mineur · S
Emplacement	package.json : 22-43	
Constat	npm outdated : next 16.2.11 -> 16.2.12, react et react-dom 19.2.4 -> 19.2.8, @playwright/test 1.61.1 -> 1.62.1, @types/react 19.2.17 -> 19.2.18, @types/react-dom 19.2.3 -> 19.2.4, @types/node 20.19.43 -> 26.1.2 (majeur), typescript 5.9.3 -> 7.0.2 (majeur). A noter : next-auth est affiche « latest 4.24.15 » car le projet suit volontairement la branche 5.0.0-beta - ce n'est pas un retard.	
Impact	Les correctifs de la branche patch (next, react) ne sont pas appliques. @types/node en version 20 alors que le runtime cible est Node 22 (CI et PM2) peut masquer des API disponibles.	
Correction	Passer les mises a jour de patch dans la foulee (next, react, react-dom, @playwright/test, @types/react*). Aligner @types/node sur ^22 pour correspondre au runtime. Traiter TypeScript 7 comme une migration a part entiere.	

9. Performance

Score **73/100**

Poids 12 %

Poids des ressources, strategie de chargement des images et des polices, requetes base de donnees. Analyse statique uniquement.

PERF-01	loading="lazy" absent sur 33 des 37 images	Majeur · S
Emplacement	src/components/team-card.tsx, match-row.tsx, player-card.tsx, tournament-card.tsx, lft-card.tsx, participant-card.tsx, player-mini-card.tsx, tournament-list-row.tsx, match-mini-list.tsx, player-career-table.tsx : 19 / 44 / 19 / 44 / 25 / 20 / 19 / 37 / 29 / 48	
Constat	37 balises dans src/ ; seules 4 portent loading="lazy" (flag.tsx:28, agent-icon.tsx:31 et 2 autres). Toutes les vignettes de listes - logos d'equipe, photos de joueurs, logos de tournoi - se chargent donc en priorite haute des le rendu, y compris celles situees hors ecran sur les pages /equipes, /matches, /tournois et /lft.	
Impact	Sur une liste de 40 equipes, 40 requetes /api/images concurrentes au chargement au lieu de 6-8. Retarde le LCP et sature le serveur Node mono-instance (PM2 fork, max_memory_restart 400M).	
Correction	Ajouter loading="lazy" decoding="async" a toutes les images de listes, en gardant le chargement immediat pour la premiere image visible des pages de detail (logo d'equipe, photo de joueur).	

PERF-02	Requetes Prisma sans pagination sur les listes principales	Majeur · M
Emplacement	src/lib/data/teams.ts, src/lib/data/tournaments.ts, src/lib/data/players.ts : 29 et 40 / 7 et 19 / 9, 14 et 40	
Constat	Les findMany qui alimentent /equipes, /tournois et /lft n'ont ni `take` ni `skip` (contrairement a matches.ts qui plafonne systematiquement via `take: limit`, lignes 168, 178, 227, 249, 259, et search.ts qui plafonne a 10). players.ts:9 est un `findMany({ orderBy: { pseudo: 'asc' } })` nu.	
Impact	Le temps de reponse et la memoire croissent lineairement avec la base. A quelques centaines de lignes l'effet est invisible ; a plusieurs milliers de joueurs, la page devient lente puis fait redemarrer le process (limite PM2 a 400 Mo).	
Correction	Introduire une pagination (take/skip ou curseur) sur ces trois listes, avec une valeur par default de 50 et une navigation par pages. Aligner la signature sur celle deja utilisee dans matches.ts.	

PERF-03	Logo de navigation de 98 Ko pour un rendu de 32 px de haut	Majeur · S
Emplacement	public/logo.png (utilise dans src/components/nav-bar.tsx:28) : 28	
Constat	public/logo.png pese 100 721 octets. Il est affiche avec la classe `h-8 w-auto`, soit 32 px de haut (64 px en densite 2x). Le fichier est charge sur toutes les pages du site puisqu'il est dans la barre de navigation.	
Impact	~98 Ko inutiles sur chaque premiere visite, soit davantage que la feuille de style complete du site (68 Ko). Penalise directement le LCP en connexion mobile.	
Correction	Reexporter le logo en WebP a 64 px et 128 px de haut (poids attendu : 3 a 6 Ko) et servir le PNG en repli. Le projet embarque deja sharp, la conversion peut etre scriptee.	

PERF-04	Trois familles de polices Google chargees globalement	Mineur · S
Emplacement	src/app/layout.tsx : 10-24	
Constat	Plus_Jakarta_Sans, Geist_Mono et Bricolage_Grotesque (3 graisses) sont declarees dans le layout racine, donc appliquees a toutes les pages. next/font les auto-heberge et pose font-display: swap, ce qui est correct, mais le volume telecharge reste celui de trois familles.	
Impact	Plusieurs dizaines de Ko de woff2 supplementaires au premier rendu. L'auto-hebergement evite en revanche toute requete vers fonts.googleapis.com, ce qui est le bon choix sur le plan RGPD.	
Correction	Verifier que Bricolage Grotesque et Geist Mono sont reellement utilisees sur toutes les pages ; sinon les charger localement dans les composants concernees. Restreindre les graisses (Plus Jakarta Sans ne declare aucun `weight`, donc toutes sont recuperees).	

PERF-05	/api/images sans ETag ni Last-Modified	Mineur · S
Emplacement	src/app/api/images/[...key]/route.ts : 17-21	
Constat	La reponse ne porte que Content-Type et Cache-Control: public, max-age=86400. Aucun validateur (ETag, Last-Modified), et pas de gestion du 304.	
Impact	Passe 24 h, chaque image est retelechargee integralement meme si elle n'a pas change, alors qu'une revalidation conditionnelle couterait quelques octets. Le fichier entier est aussi lu en memoire (fs.readFile) a chaque miss de cache.	
Correction	Calculer un ETag a partir de mtime + taille (fs.stat), repondre 304 si If-None-Match correspond, et allonger max-age. Les cles etant stables par identifiant, envisager un suffixe de version pour pouvoir passer en `immutable`.	

10. Accessibilite

Score 80/100

Poids 12 %

Reference WCAG 2.2 niveau AA. Contrastes calcules sur les jetons de globals.css ; structure et attributs verifiees dans le JSX.

A11Y-01	Aucun lien d'evitement vers le contenu principal	Majeur · S
Emplacement	src/app/layout.tsx : 58-79	
Constat	Le layout racine enchaîne NavBar, contenu et Footer sans lien d'evitement. La barre de navigation contient le logo, 4 a 5 liens, un champ de recherche et le menu utilisateur : un utilisateur au clavier doit les traverser sur chaque page. Aucune occurrence de « skip » ou « Aller au contenu » dans src/.	
Impact	Echec du critere WCAG 2.2 2.4.1 (Contourner des blocs), niveau A - le niveau le plus eleve d'exigence. Penalise navigation clavier et lecteurs d'ecran.	
Correction	Ajouter en premier enfant du <body> un lien Aller au contenu` et poser `id="contenu"` sur le conteneur ligne 68. Le site n'a pas encore de classe sr-only : Tailwind 4 la fournit nativement.	

A11Y-02	Contraste insuffisant du token --text-subtle (3,5:1)	Majeur · S
Emplacement	src/app/globals.css : 19	
Constat	--text-subtle: #6f7178. Ratios calcules : 3,73:1 sur --bg (#131619), 3,50:1 sur --card (#191c22) et 3,02:1 sur --card-hover (#242832). Le seuil WCAG AA pour du texte normal est 4,5:1. Le token est utilise 26 fois dans src/ (dont les separateurs et mentions du footer, footer.tsx:38 et :42). Les autres tokens passent : --text 17,4:1, --text-muted 6,21:1, --accent 5,07:1 sur carte.	
Impact	Echec du critere WCAG 2.2 1.4.3 (Contraste minimum), niveau AA, sur tout texte de taille normale utilisant ce token - et l'ecart se creuse au survol des cartes.	
Correction	Eclaircir --text-subtle a environ #8a8c92 (~4,6:1 sur --card) ou reserver strictement le token actuel aux elements non textuels (separateurs, icones decoratives). Un seul changement de variable corrige les 26 usages.	

A11Y-03	outline supprime sur les champs, indicateur de focus reduit a la bordure	Mineur · S
Emplacement	src/app/globals.css:359-360, src/components/team-form.tsx:34, profile-fields.tsx:7, riot-id-form.tsx:7, country-select.tsx:79, clearable-search.tsx:201, nav-bar.tsx:50, src/app/onboarding/page.tsx:10, recherche/page.tsx:31, rejoindre/[token]/page.tsx:110 : 359-360	
Constat	10 emplacements neutralisent le contour natif (`outline: none` ou `outline:none` / `focus:outline:none`). Le remplacement est un simple changement de couleur de bordure vers --accent. Ce contour orange offre 5,07:1 contre la carte, donc le focus reste percevable, mais il ne se distingue que par la teinte sur une bordure de 1 px.	
Impact	Conforme au minimum WCAG 2.2 2.4.7 (Visibilite du focus, AA), mais en dessous de 2.4.13 (Apparence du focus, AAA) : indicateur fin, sans epaisseur ni decalage. Difficile a reperer pour une basse vision.	
Correction	Remplacer par un anneau explicite : `focus-visible:outline-2 focus-visible:outline-offset-2 focus-visible:outline-[var(--accent)]`. Passer de :focus a :focus-visible evite d'afficher l'anneau au clic souris.	

A11Y-04	Cible tactile de 32x32 px pour le bouton de recherche mobile	Mineur · S
Emplacement	src/components/nav-bar.tsx : 35	
Constat	Le lien vers /recherche affiche sous 640 px utilise `h-8 w-8`, soit 32x32 px. Les liens de navigation, eux, s'etirent sur les 47 px de la barre et sont conformes.	
Impact	Conforme au critere WCAG 2.2 2.5.8 (Taille de cible minimale, AA, seuil 24x24) mais sous la recommandation usuelle de 44x44 px. Cible la plus petite du site, dans la zone la plus utilisee sur mobile.	
Correction	Passer a `h-11 w-11` (44 px), ou conserver le visuel a 32 px et elargir la zone cliquable par du padding.	

11. Securite

Score 57/100

Poids 15 %

En-tetes HTTP, dependances, cookies, autorisation, limitation de debit. Aucune faille applicative n'a ete trouvee dans le code lui-meme.

SEC-01	Vulnerabilite haute dans postcss (dependance transitive de next)	Majeur · S
Emplacement	package-lock.json (node_modules/next/node_modules/postcss)	
Constat	npm audit remonte 3 vulnerabilites : postcss <=8.5.17 - GHSA-r28c-9q8g-f849 (path traversal via sourceMappingURL, CVSS 7.5, haute), GHSA-6g55-p6wh-862q (lecture de fichier arbitraire, CVSS 7.5, haute), GHSA-qx2v-qp2m-jg93 (XSS via </style> non echappe, CVSS 6.1). La chaine est postcss -> next -> next-auth. `npm audit fix --force` proposerait next@9.3.3, une regression majeure inacceptable.	
Impact	Exploitable uniquement au moment de la compilation CSS, sur des feuilles de style controlees par un attaquant. Le risque reel est faible ici (aucun CSS tiers n'est compile), mais la dependance reste signalee et bloquera tout controle de securite automatise.	
Correction	Forcer la resolution via le champ `overrides` deja present dans package.json : ajouter `"postcss": "^8.5.18"` a cote de l'override `sharp` existant, puis `npm install` et verifier que le build Tailwind passe. Suivre les releases next 16.2.x qui remonteront la contrainte.	

SEC-02	Aucune Content-Security-Policy	Majeur · M
Emplacement	next.config.ts : 5-9	
Constat	Le tableau securityHeaders ne contient que X-Content-Type-Options, X-Frame-Options et Referrer-Policy. Le commentaire ligne 3-4 documente le report de la CSP (« necessite un travail sur les nonces Next.js -> a ajouter au Plan 4 »), mais elle n'a pas ete ajoutez. Aucune directive CSP non plus dans deploy/apache.conf.	
Impact	Aucune defense en profondeur contre l'injection de script. Le code est aujourd'hui sain (0 innerHTML, 0 eval), mais une CSP est la seule barriere qui subsiste si une faille XSS apparait, et elle bloquerait aussi l'exfiltration vers un domaine tiers.	
Correction	Commencer par une CSP en Report-Only pour mesurer, puis appliquer. Les sources externes a autoriser sont connues et peu nombreuses : img-src 'self' data: https://media.valorant-api.com https://flagcdn.com ; connect-src 'self' ; frame-ancestors 'none'. Pour script-src, utiliser les nonces Next 16 (voir node_modules/next/dist/docs sur la CSP) plutot que 'unsafe-inline'.	

SEC-03	En-tete Strict-Transport-Security absent	Majeur · S
Emplacement	next.config.ts / deploy/apache.conf : 5-9 / 9-36	
Constat	Aucun HSTS n'est emis, ni par Next (securityHeaders) ni par Apache. Le VirtualHost versionne n'ecoute que sur le port 80 et delegue le HTTPS a la generation certbot, qui n'ajoute pas HSTS par default.	
Impact	Un visiteur qui tape le domaine sans schema fait un premier aller-retour en clair, interceptable (SSL stripping). Le cookie de session Auth.js voyage sur cette premiere requete si la redirection est manquee.	
Correction	Ajouter dans securityHeaders : { key: 'Strict-Transport-Security', value: 'max-age=63072000; includeSubDomains; preload' }. Verifier en parallele que le VirtualHost :80 genere par certbot redirige bien en 301 vers :443, et documenter cette redirection dans deploy/apache.conf plutot que de la laisser implicite.	

SEC-04	Aucune limitation de debit applicative	Majeur · M
Emplacement	src/app/**/actions.ts, src/app/api/images/[...key]/route.ts, src/lib/henrikdev.ts	
Constat	Recherche exhaustive sur src/ : aucune implementation de rate limiting (les seules occurrences de RATE_LIMITED sont la gestion du 429 renvoye par HenrikDev, henrikdev.ts:35 et :103). Les server actions d'ecriture, la route /api/images et surtout la verification de Riot ID - qui declenche un appel sortant facture vers api.henrikdev.xyz - sont appelables en boucle par tout utilisateur authentifie.	
Impact	Epuisement du quota HenrikDev (le site perd la verification de Riot ID pour tous), saturation disque/CPU via les envois d'images repetes (5 Mo x N), et enumeration possible des Riot ID.	
Correction	Poser un compteur par utilisateur et par IP sur les actions couteuses. Sans Redis, une table Prisma `RateLimit(key, window, count)` avec fenetre glissante suffit a ce volume. Prioriser resolveRiotAccount (src/lib/riot-account.ts) et les actions d'upload d'image.	

SEC-05	En-tete Permissions-Policy absent	Mineur · S
Emplacement	next.config.ts : 5-9	
Constat	Aucune Permissions-Policy n'est declaree ; le navigateur autorise donc par default camera, micro, geolocalisation, capteurs a tout script de la page.	
Impact	Surface d'abus supplementaire en cas de compromission d'un script. Point systematiquement releve par les scanners de securite.	
Correction	Ajouter { key: 'Permissions-Policy', value: 'camera=(), microphone=(), geolocation=(), interest-cohort=()' } - le site n'utilise aucune de ces API.	

SEC-06	En-tete X-Powered-By: Next.js expose	Mineur · S
Emplacement	next.config.ts : 11-29	
Constat	`poweredByHeader` n'est pas desactive. Verifie dans node_modules/next/dist/server/config-shared.js:101 : la valeur par default est `true`, l'en-tete X-Powered-By: Next.js est donc emis sur chaque reponse.	
Impact	Divulgateur de la technologie et facilitation du ciblage d'exploits connus. Impact faible mais correction triviale.	
Correction	Ajouter `poweredByHeader: false` dans nextConfig.	

SEC-07	Cookie `onboarded` sans HttpOnly ni Secure, et gate contournable cote client	Mineur · S
Emplacement	src/app/api/onboarded/route.ts : 35-39	
Constat	res.cookies.set('onboarded', '1', { path, sameSite: 'lax', maxAge }) : ni `httpOnly: true` ni `secure: true`. Le cookie est donc lisible et modifiable en JavaScript, et transmis en clair sur une eventuelle requete HTTP. Le commentaire ligne 29-30 explicite l'intention (« sinon il suffirait de visiter cette URL pour sauter l'onboarding ») : la verification du puuid protege bien la route, mais le gate de src/proxy.ts:19 ne teste que la presence du cookie - `document.cookie = 'onboarded=1'` suffit a le franchir.	
Impact	Aucune donnee exposee et aucune elevation de privilege : l'utilisateur peut seulement sauter un formulaire d'accueil. L'invariant fonctionnel « tout compte connecte a un Riot ID lie » n'est pas garanti.	
Correction	Ajouter `httpOnly: true` et `secure: process.env.NODE_ENV === 'production'`. Si l'invariant compte vraiment, remplacer le test de presence du cookie dans proxy.ts par une verification serveur du puuid (le cookie ne servant plus que de cache).	

SEC-08	Pas d'audit de dependances dans la CI	Mineur · S
Emplacement	.github/workflows/ci.yml : 20-42	
Constat	La CI enchaîne npm ci, prisma generate, tsc --noEmit, npm test et npm run build. Aucune étape `npm audit`. La vulnérabilité SEC-01 est donc passée inaperçue.	
Impact	Les vulnérabilités de dépendances ne sont détectées qu'à l'occasion d'un audit manuel comme celui-ci.	
Correction	Ajouter une étape `npm audit --audit-level=high` (non bloquante au début avec `continue-on-error: true`, puis bloquante), ou activer Dependabot dans .github/.	

SEC-09	Redirection HTTP -> HTTPS non versionnée	Mineur · S
Emplacement	deploy/apache.conf : 9-36	
Constat	Le seul VirtualHost du depot ecoute sur *:80 et proxifie directement vers 127.0.0.1:3200. La configuration HTTPS est produite hors depot par `certbot --apache` (commentaire lignes 6-7).	
Impact	La configuration réelle de production ne peut pas être reconstruite depuis le depot, et rien ne garantit la redirection 301 ni sa persistance après une réinstallation.	
Correction	Versionner le VirtualHost :443 complet et réduire le :80 à une simple `Redirect permanent / https://the-hub-vrc.fr/`, en documentant les chemins de certificats attendus.	

12. SEO technique

Score **80/100**

Poids 10 %

Exploration, indexation, donnees structurees, canoniques.

SEO-01	robots.txt absent	Majeur · S
Emplacement	src/app/ (robots.ts attendu) / public/	
Constat	Aucun fichier robots.txt dans public/, aucune route src/app/robots.ts. Le site repond donc 404 sur /robots.txt.	
Impact	Aucune directive d'exploration. Les zones privees (/admin, /*/gestion, /profil, /onboarding, /rejoindre/[token]) sont exposees a l'exploration - elles redirigent bien vers / pour un visiteur non autorise, mais leurs URLs se retrouvent dans les rapports d'exploration, et les liens d'invitation peuvent fuir via les referrers.	
Correction	Creer src/app/robots.ts avec l'API MetadataRoute.Robots de Next : autoriser /, interdire /admin, /profil, /onboarding, /rejoindre et les chemins /gestion, et declarer le sitemap.	

SEO-02	sitemap.xml absent	Majeur · M
Emplacement	src/app/ (sitemap.ts attendu)	
Constat	Aucun sitemap statique ni route src/app/sitemap.ts. Le site est pourtant presque entierement compose de pages dynamiques a forte valeur SEO : /equipes/[id], /joueurs/[id], /tournois/[id], /matches/[id].	
Impact	L'indexation ne repose que sur le maillage interne. Les fiches profondes (un match dans un tournoi termine) peuvent rester longtemps inconnues des moteurs, alors que c'est precisement le contenu differenciant du site.	
Correction	Ajouter src/app/sitemap.ts generant les URLs depuis Prisma (equipes, joueurs, tournois, matches) avec lastModified, en excluant les zones privees. Les fonctions de la couche src/lib/data/ sont directement reutilisables.	

SEO-03	Aucune donnee structuree Schema.org / JSON-LD	Mineur · M
Emplacement	src/app/**/page.tsx	
Constat	Recherche sans resultat sur application/ld+json dans tout src/. Les pages de match, de tournoi, d'equipe et de joueur decrivent pourtant des entites que Schema.org modelise directement (SportsEvent, SportsTeam, Person, Organization).	
Impact	Aucun resultat enrichi possible dans les moteurs. Manque a gagner sur la visibilite, sans consequence technique.	
Correction	Ajouter un <script type="application/ld+json"> serialise cote serveur sur /tournois/[id] (SportsEvent), /matches/[id] (SportsEvent), /equipes/[id] (SportsTeam) et /joueurs/[id] (Person). Serialiser avec JSON.stringify et non par concatenation.	

SEO-04	Pages privees sans directive noindex	Mineur · S
Emplacement	src/app/admin/**, src/app/**/gestion/**, src/app/profil/page.tsx, src/app/onboarding/page.tsx	
Constat	Aucune de ces pages n'exporte `robots: { index: false }` dans ses metadonnees. Elles sont protegees par redirection serveur, mais rien n'indique aux moteurs de ne pas les indexer.	
Impact	Faible - un robot non authentifie est redirige vers /. En complement de l'absence de robots.txt (SEO-01), les URLs restent neanmoins decouvables.	
Correction	Ajouter `robots: { index: false, follow: false }` aux metadata de ces sections, en plus du robots.txt.	

13. Conformite legale

Score 80/100

Poids 12 %

LCEN, RGPD et lignes directrices CNIL. Les contenus legaux sont de bonne qualite ; les problemes portent sur leur accessibilite et leur exhaustivite.

LEG-01	Liens vers les mentions legales, la confidentialite et les CGU masques sous 640 px	Majeur · S
Emplacement	src/components/footer.tsx : 34	
Constat	Le bloc contenant les trois liens legaux porte `hidden items-center gap-x-3 text-xs sm:flex` : il est donc invisible en dessous du point de rupture `sm` (640 px). Aucun autre acces a ces pages n'existe dans la navigation (src/components/nav-links.tsx:6-11 ne liste que Tournois, Matches, Equipes, LFT, Admin). Sur mobile, les pages /mentions-legales, /confidentialite et /cgu ne sont atteignables qu'en tapant l'URL.	
Impact	L'article 6 III de la LCEN impose des mentions legales accessibles a tout visiteur, et l'article 12 du RGPD une information « aisement accessible ». Le contenu existe et est de bonne qualite, mais il est inaccessible a la majorite du trafic d'un site esport.	
Correction	Retirer `hidden ... sm:flex` et laisser les liens passer a la ligne sur mobile (le footer devra abandonner sa hauteur fixe de 47 px au profit d'une hauteur automatique sous 640 px).	

LEG-02	Images tierces (flagcdn.com, media.valorant-api.com) non declarees dans la politique de confidentialite	Majeur · M
Emplacement	src/components/flag.tsx:22-23, src/lib/agents.ts:4-48, src/app/confidentialite/page.tsx:126-146 : 22 / 4 / 126	
Constat	Les drapeaux de nationalite sont charges depuis https://flagcdn.com (flag.tsx:22-23, src + srcSet) et les 45 icones d'agents depuis https://media.valorant-api.com (agents.ts). Ces requetes partent du navigateur du visiteur et transmettent donc son adresse IP, son User-Agent et le Referer a ces deux domaines. La section « Destinataires et sous-traitants » de la politique (confidentialite/page.tsx:126-146) ne cite que Discord, HenrikDev et OVH.	
Impact	Divulgarion a des tiers non documentee, contraire a l'obligation d'information des articles 13 et 14 du RGPD. La CNIL considere le chargement de ressources tierces comme un traitement a mentionner, meme sans cookie depose. La politique affirme par ailleurs qu'il n'y a « ni traceur tiers » (ligne 154-155), ce qui devient discutable.	
Correction	Deux options. (1) Recommandee : rapatrier les ressources - les 45 icones d'agents et les drapeaux sont des jeux finis et stables, a telecharger une fois dans public/ ; cela supprime le probleme juridique, retire deux domaines de la CSP et accelere le rendu. (2) A default, ajouter flagcdn.com et valorant-api.com a la liste des destinataires de la politique.	

LEG-03	La politique de confidentialite decrit un seul cookie alors que le site en pose deux	Mineur · S
Emplacement	src/app/confidentialite/page.tsx:151-156 vs src/app/api/onboarded/route.ts:35-39 : 153	
Constat	La section Cookies affirme : « Le site depose uniquement un cookie de session, strictement necessaire au maintien de votre connexion. » Or /api/onboarded pose un second cookie, `onboarded`, d'une duree de un an (maxAge: 60*60*24*365). Il est fonctionnel et donc bien exempt de consentement, mais il n'est pas decrit et sa duree contredit la mention « Se deconnecter supprime ce cookie » (ligne 156).	
Impact	Inexactitude de l'information fournie a la personne concernee (article 13 RGPD). Consquence faible - la conclusion « pas de bandeau necessaire » reste juridiquement correcte - mais c'est le premier point verifie lors d'un controle.	
Correction	Compléter la section : lister les deux cookies (nom, finalite, duree) et corriger la phrase sur la deconnexion, `onboarded` n'etant pas supprime par signOut.	

LEG-04	Pas de suppression de compte en libre-service	Mineur · M
Emplacement	src/app/profil/actions.ts, src/app/profil/page.tsx	
Constat	Aucune action de suppression de compte n'existe (recherche de « supprim » et « delete » dans les deux fichiers : aucun resultat). La politique renvoie vers le serveur Discord pour exercer ses droits (confidentialite/page.tsx:174).	
Impact	Le droit a l'effacement (article 17 RGPD) est satisfait puisqu'un canal existe, mais il repose sur un traitement manuel et sur la disponibilite d'un unique administrateur. Aucun delai n'est garanti techniquement.	
Correction	Ajouter un bouton « Supprimer mon compte » sur /profil avec confirmation. Le schema Prisma est deja pret : onDelete: Cascade sur Account et Session, onDelete: SetNull sur Player.userId (prisma/schema.prisma:47, 57, 122), ce qui produit exactement la dissociation decrite dans la politique.	

14. Qualite du code

Score 90/100

Poids 10 %

Gestion des erreurs, journalisation, dette technique. Aucun TODO, FIXME ou HACK dans src/.

QUA-01	Aucune frontiere d'erreur : ni error.tsx, ni not-found.tsx, ni global-error.tsx	Majeur · S
Emplacement	src/app/	
Constat	Le seul fichier de convention present est src/app/loading.tsx. Or notFound() est appele dans plusieurs pages (equipes/[id]/gestion/page.tsx:32, invitation/page.tsx:25, admin/joueurs/[id]/page.tsx, etc.) et les server actions levent des exceptions nues : `throw new Error("FORBIDDEN")` (server-auth.ts:13, 29, 47), 'INVALID_INVITE', 'UNAUTHENTICATED', 'ALREADY_IN_TEAM' (rejoindre/actions.ts:17, 20, 23, 49).	
Impact	Un joueur qui ouvre un lien d'invitation expire ou deja utilise voit la page d'erreur brute de Next, sans identite visuelle, sans explication et sans chemin de retour - sur un parcours d'entree pourtant central. Idem pour toute URL inexistante.	
Correction	Ajouter src/app/not-found.tsx et src/app/error.tsx aux couleurs du site, avec un retour vers l'accueil. Traduire les codes d'erreur metier existants en messages : le mecanisme de messages flash (src/lib/flash-messages.ts) fournit deja les libelles.	

QUA-02	Journalisation par console.error, sans logger structure	Mineur · S
Emplacement	src/app/admin/actions/matches.ts : 115	
Constat	`console.error('fetchAndStoreMatchStats failed', e)` est la seule trace applicative de tout src/. Elle atterrit dans ../../shared/logs/error.log via PM2 (ecosystem.config.cjs:24), melangee aux traces du runtime, sans niveau, sans horodatage structure ni contexte (identifiant du match, utilisateur).	
Impact	Le point d'integration le plus fragile - la recuperation de statistiques depuis HenrikDev - est le moins observable. Un diagnostic exige de lire un fichier de log brut sur le serveur.	
Correction	Introduire un logger minimal (pino convient a une instance unique) avec niveaux et champs structures, et journaliser aussi les echecs d'autorisation et les erreurs Riot ID.	

15. Mobile & PWA

Score **97/100**

Poids 3 %

Viewport, cibles tactiles, manifeste, icones.

PWA-01	manifest.json absent	Mineur - S
Emplacement	src/app/ (manifest.ts attendu) / public/	
Constat	Aucun manifeste d'application ni route src/app/manifest.ts. Les icones existent pourtant (src/app/icon.png 31 Ko, src/app/apple-icon.png 6,4 Ko, detectees automatiquement par Next) et le site est deja utilisable hors ligne au sens ou il n'a pas d'etat client complexe.	
Impact	Pas d'ajout a l'ecran d'accueil sur Android, pas de couleur de theme sur la barre systeme, pas d'icone maskable. Aucun impact fonctionnel.	
Correction	Ajouter src/app/manifest.ts (MetadataRoute.Manifest) : name, short_name, start_url, display: standalone, background_color et theme_color alignes sur --shell (#0d0f10) et --accent (#ED5E29), et une icone maskable 512x512.	

16. Contenu & editorial

Score **94/100**

Poids 3 %

Mentions affichees, fraicheur, coherence. Verification orthographique par echantillonnage.

CNT-01	Mention de non-affiliation a Riot Games masquee sous 640 px	Mineur - S
Emplacement	src/components/footer.tsx : 30	
Constat	`<p className="hidden text-center text-xs sm:block">Projet non affilie a Riot Games.</p>` : la mention disparaît en dessous de 640 px, comme les liens legaux (LEG-01).	
Impact	C'est la clause de non-affiliation exigee par la politique des droits de Riot Games pour les projets communautaires. Elle est invisible pour la majorite des visiteurs mobiles, alors que le site utilise des icones d'agents et des noms de cartes Valorant.	
Correction	Afficher la mention a toutes les tailles, quitte a la reduire ou a la placer sur une seconde ligne du footer mobile. A traiter avec LEG-01, meme fichier et meme cause.	

CNT-02	Pas d'annee de copyright dans le pied de page	Mineur - S
Emplacement	src/components/footer.tsx : 9-64	
Constat	Le footer affiche « made by Lurrod », la mention Riot, les liens legaux et deux reseaux sociaux, mais aucune mention de copyright ni annee. La seule date visible du site est LEGAL_UPDATED = « 29 juillet 2026 » (src/components/legal.tsx:4), affichee en tete des pages legales.	
Impact	Signal de fraicheur absent, et propriete intellectuelle non revendiquee en pied de page alors que les mentions legales comportent une section « Propriete intellectuelle » (mentions-legales/page.tsx:51).	
Correction	Ajouter « (c) 2026 The Hub » calcule cote serveur, ce qui evite tout ecart d'hydratation avec new Date() cote client.	

17. Plan d'action priorise

Les lots sont construits par cout croissant, pas par severite : le premier regroupe tout ce qui se corrige en quelques lignes et produit un effet immediat.

Lot 1 - Gains rapides (moins d'une journee)

Quinze corrections a effort S, dont les quatre plus urgentes du rapport. Aucune ne touche l'architecture ; toutes sont couvertes par les tests existants.

ID	Action	Domaine	Sev.	Eff.
LEG-01	Liens vers les mentions legales, la confidentialite et les CGU masques sous 640 px	Conformite legale	Maj	S
A11Y-01	Aucun lien d'evitement vers le contenu principal	Accessibilite	Maj	S
A11Y-02	Contraste insuffisant du token --text-subtle (3,5:1)	Accessibilite	Maj	S
PERF-03	Logo de navigation de 98 Ko pour un rendu de 32 px de haut	Performance	Maj	S
PERF-01	loading="lazy" absent sur 33 des 37 images	Performance	Maj	S
SEC-03	En-tete Strict-Transport-Security absent	Securite	Maj	S
SEC-05	En-tete Permissions-Policy absent	Securite	Min	S
SEC-06	En-tete X-Powered-By: Next.js expose	Securite	Min	S
SEC-07	Cookie `onboarded` sans HttpOnly ni Secure, et gate contournable cote client	Securite	Min	S
SEO-01	robots.txt absent	SEO technique	Maj	S
QUA-01	Aucune frontiere d'erreur : ni error.tsx, ni not-found.tsx, ni global-error.tsx	Qualite du code	Maj	S
LEG-03	La politique de confidentialite decrit un seul cookie alors que le site en pose deux	Conformite legale	Min	S
HTM-01	openGraph.url figee sur l'accueil pour toutes les pages	HTML & semantique	Min	S
HTM-02	Aucune URL canonique declaree	HTML & semantique	Min	S
CNT-01	Mention de non-affiliation a Riot Games masquee sous 640 px	Contenu & editorial	Min	S

Lot 2 - Court terme (moins d'une semaine)

Remise en place de l'outillage qualite et des protections d'infrastructure. C'est le lot qui empeche les regressions futures.

ID	Action	Domaine	Sev.	Eff.
SEC-01	Vulnerabilite haute dans postcss (dependance transitive de next)	Securite	Maj	S
ARC-01	Aucun linter configure, avec 38 directives eslint-disable orphelines	Architecture	Maj	M
ARC-03	Couverture de tests non mesuree	Architecture	Maj	S
SEO-02	sitemap.xml absent	SEO technique	Maj	M
SEC-08	Pas d'audit de dependances dans la CI	Securite	Min	S
JS-01	Neuf dependances en retard, dont next et react	JavaScript	Min	S
ARC-04	README reste le gabarit create-next-app	Architecture	Min	S
PWA-01	manifest.json absent	Mobile & PWA	Min	S
A11Y-03	outline supprime sur les champs, indicateur de focus reduit a la bordure	Accessibilite	Min	S
PERF-05	/api/images sans ETag ni Last-Modified	Performance	Min	S
QUA-02	Journalisation par console.error, sans logger structure	Qualite du code	Min	S

Lot 3 - Moyen terme (moins d'un mois)

Chantiers demandant conception et validation : CSP, limitation de debit, pagination, rapatriement des ressources tierces et couverture end-to-end.

ID	Action	Domaine	Sev.	Eff.
LEG-02	Images tierces (flagcdn.com, media.valorant-api.com) non declarees dans la politique de confidentialite	Conformite legale	Maj	M
SEC-02	Aucune Content-Security-Policy	Securite	Maj	M
SEC-04	Aucune limitation de debit applicative	Securite	Maj	M
PERF-02	Requetes Prisma sans pagination sur les listes principales	Performance	Maj	M
ARC-02	Tests end-to-end absents de la CI et du deploiement	Architecture	Maj	M
LEG-04	Pas de suppression de compte en libre-service	Conformite legale	Min	M
CSS-01	globals.css monolithique de 1 392 lignes	CSS & design system	Min	M
SEO-03	Aucune donnee structuree Schema.org / JSON-LD	SEO technique	Min	M

Lot 4 - Fond de tiroir

Points sans urgence, a traiter a l'occasion d'un passage dans les fichiers concernes.

ID	Action	Domaine	Sev.	Eff.
SEC-09	Redirection HTTP -> HTTPS non versionnee	Securite	Min	S
SEO-04	Pages privees sans directive noindex	SEO technique	Min	S
PERF-04	Trois familles de polices Google chargees globalement	Performance	Min	S
A11Y-04	Cible tactile de 32x32 px pour le bouton de recherche mobile	Accessibilite	Min	S
ARC-05	Pas de .editorconfig	Architecture	Inf	S
CNT-02	Pas d'annee de copyright dans le pied de page	Contenu & editorial	Min	S

18. Annexes

18.1 Ce qui n'a pas pu etre teste

Controle	Raison
Validation W3C (html-validate)	Aucun fichier HTML statique : le HTML est genere a l'execution par React Server Components. Necessiterait un serveur de production et une base PostgreSQL accessibles.
Audit d'accessibilite automatise (axe-core / pa11y)	Meme raison : requiert des URLs servies. Seule l'analyse statique du code JSX et le calcul des contrastes ont pu etre faits.
Lighthouse / mesures Core Web Vitals	Requiert le site en fonctionnement (serveur + base). Seule l'analyse statique des bundles .next/static a ete faite.
Detection de duplication (jscpd)	Outil non installe ; installation refusee par principe de non-modification du projet audite.
Analyse des regles CSS inutilisees (PurgeCSS)	Tailwind CSS 4 purge deja a la compilation ; une mesure fiable exigerait de servir le site.
Orthographe exhaustive	Echantillonnage manuel sur les pages legales, le footer et la navigation. Aucune erreur relevee sur l'echantillon ; le controle n'est pas exhaustif.
composer audit	Projet sans PHP.

18.2 Environnement et versions d'outils

Systeme	Windows 11 (26200), shell bash + PowerShell
Node.js	v22.11.0
npm	10.9.0
Python	3.13.2 (reportlab, openpyxl - generation des livrables)
Depot	branche main, 142 commits, HEAD f2b98d0 du 31/07/2026, arbre propre
Volume audite	151 fichiers dans src/ (~15 051 lignes), 25 fichiers de test, 19 migrations Prisma

18.3 Commandes executees

Toutes les commandes sont en lecture seule. Aucun fichier source n'a ete modifie : le seul ajout au depot est le dossier audit/ contenant les deux livrables.

Inventaire

```
find . -maxdepth 2 -not -path './node_modules/*'
find src tests prisma -type f | sort
wc -l $(find src -name '*.ts*' -o -name '*.css')
du -sh public uploads .next
```

Types & tests

```
npx tsc --noEmit -> 0 erreur
npm test -> 18 fichiers, 169 tests, 0 echec
```

Dependances

```
npm audit --json -> 1 haute, 2 moderees (postcss)
npm outdated -> 9 paquets en retard
npm view next version -> 16.2.12
```

Secrets

```
git ls-files | grep -iE '\.env|secret|credential|\.pem|\.key'
grep -oE '^[A-Z_0-9]+=' .env .env.local .env.example (noms seuls)
```

Motifs dangereux

```
grep -rn 'dangerouslySetInnerHTML|innerHTML|eval\(|document.write|new Function\(' src/
grep -rn ': any| as any' src/
grep -rn 'http://' src/
```

Accessibilite

```
grep -rn '<img' src/ ; comptage alt=, loading=, aria-, htmlFor
grep -n 'focus-visible|outline|prefers-reduced-motion' src/app/globals.css
calcul WCAG des ratios de contraste sur les jetons :root
```

SEO / conformite

```
find src public -iname 'robots*' -o -iname 'sitemap*' -o -iname 'manifest*'
grep -rn 'export const metadata|generateMetadata' src/app
grep -rniE 'gtag|google|tagmanager|fbq|hotjar|matomo|plausible|posthog' src/ public/
```

Autorisation

```
grep -rn 'requireAdmin|assertCanManage|getSessionUser|isAdmin' src/app/**/actions.ts
src/app/**/page.tsx
```

Base de donnees

```
grep -rn 'findMany|take|skip|cursor:' src/lib/data/
grep -n '@@index|@@unique|@relation' prisma/schema.prisma
```

18.4 Ratios de contraste calcules

Formule WCAG 2.x (luminance relative), appliquee aux valeurs litterales de src/app/globals.css lignes 3-33. Seuils : 4,5:1 pour du texte normal, 3:1 pour du grand texte et les composants d'interface.

Premier plan	Fond	Ratio	AA texte normal
--text #fafafa	--bg #131619	17,40	conforme
--text-muted #9b9c9e	--bg #131619	6,61	conforme
--text-muted #9b9c9e	--card #191c22	6,21	conforme
--text-subtle #6f7178	--bg #131619	3,73	ECHEC
--text-subtle #6f7178	--card #191c22	3,50	ECHEC
--text-subtle #6f7178	--card-hover #242832	3,02	ECHEC
--accent #ED5E29	--bg #131619	5,39	conforme
--accent #ED5E29	--card #191c22	5,07	conforme
--accent-foreground #131619	--accent #ED5E29	5,39	conforme
--success #4ac97e	--card #191c22	8,08	conforme
--destructive #f7665e	--card #191c22	5,70	conforme
--legendary #ffd47d	--card #191c22	12,16	conforme

Fin du rapport. Le detail exploitable des 40 findings, filtrable et triable, se trouve dans le classeur audit-findings.xlsx livre conjointement.